研究進捗と今後の実施計画

Androidアプリの通信ポリシー照合支援

2026年10月29日現在

2026年10月29日時点。端末原本を受領して照合した結果と、計画・実施申告を区別する。提出期日や最低実験数の特段の指定はない。通信なしの追加実験は、利用者の希望により他の実験後に行う。

研究の目的

開発者が事前に宣言した許可・禁止・未指定のポリシーと、APKの静的情報・通信メタデータを照合し、根拠と不足情報を提示する。判定、観測段階、アプリ帰属、本文可視性を分離する。アプリ全体の安全性、漏えい、通信の必要性を自動確定する研究とはしない。

現在の到達点

項目	確認済み	残る作業
Pythonシステム	静的解析、CSV/PCAP取込み、規則、証拠索引、HTML/CSV/JSON	独立正解による本評価
静的素材	自作10 APK・103項目の回帰確認	実SDK・独立素材・反復性能の整理
自動テスト	現時点で総数88件が成功	新しい変更ごとの必要な試験
端末取得	Mac/API35で半自動ランナーを実行。取得前APK/UID/ポリシー、時計、画面、ログを保存	HTTPS・意図的失敗・同時通信等のシナリオ
HTTP照合	http-004で取込みと3方式の事後説明用比較、44索引を検証	事前固定の本評価条件で比較
実測	下記8試行を受領・確認	未受領の実施済み原本の整理
理論・論文	モデル・設計・実装・予備実測を草稿化	査読文献比較、新規性、著者・指導教員の確認

103項目や88テストは研究上の検出精度ではない。従来の自動ADB/Emulator PCAP経路と、実測したPCAPdroid半自動経路は分けて扱う。

照合済みの半自動8試行

条件	試行ID	サーバー等の結果	CSVの対象識別
HTTP	http-auto-001	200応答、POST 1件	UID 10207・対象package
通信なし	offline-auto-001	`local_only_completed`、対象受信0件	対象UIDの行0件
短時間UDP	udp-auto-001	UDP受信1件	UID -1・Unknown
短時間UDP	udp-short-001	UDP受信1件	UID -1・Unknown
2秒保持UDP	udp-hold-001	UDP受信1件	UID 10210・対象package
2秒保持UDP	udp-hold-002	UDP受信1件	UID 10210・対象package
2秒保持UDP	udp-hold-003	UDP受信1件	UID 10210・対象package
2秒保持UDP	udp-long-001	UDP受信1件	UID 10210・対象package

8 ZIPの各28保存ファイルについて計224参照のhashを照合した。重複するAPK等を含む参照検査数であり、224個の独立データではない。APK、取得前ポリシー、端末UID、前後時計差を再確認し、受信データは試行IDと本文hashで照合した。データ表は `docs/generated/current-experiments.json`。

旧ui-check-001とhttp-004は別の予備記録として保存し、この8試行へ重複算入しない。手動HTTPの接続エラー・UDPのUnknownという追加申告も、原本のある試行と混同しない。offline-auto-002/003や残りHTTP/短時間UDPのZIPは現時点で未受領として扱う。

UDPから得られた知見

受領データでは短時間版2/2でUID不明、保持版4/4で識別できた。保持ログは約2.001〜2.002秒。短時間通信のUID不明は公式FAQにも記載され、今回の結果は寿命・照会タイミングの影響という仮説を支持する。ただし単一AVD・自作アプリ・少数反復であり、原因確定や一般精度100%ではない。

版1.1と1.2、実行順、保持用ログが異なる。またudp-short-001の本文は19 bytes、udp-long-001は18 bytesである。次の厳密比較では同じAPK・同じ本文長とし、保持時間だけを変える。

UID不明は通信なしではない。サーバー受信があれば送受信の証拠となるが、CSVのUIDを後から書き換えない。通信なしも指定窓での未観測であり、全経路の不存在と解釈しない。時計差は前後バッチに整合する定数モデル、連続取得は実験者申告であるため、品質partialを維持する。

今後の実施順序

1. 既存データの整理

実施済み原本を集め、ID・版・APK hash・条件を一覧化する。重複実行は要求せず、確認できた試行を使う。HTTPの追加反復や短時間UDPの追加が実施済みなら先に受領する。保持条件の単純反復は4回あるため一旦区切る。

2. UDPの条件を統制する小実験

GPT側で保持時間を入力パラメータで切り替える単一APKとランナーを準備する。現配布版にその切替機能があるとはしない。入力本文の長さ、package、署名、UID、観測窓の起点を固定し、0ms/2000msを事前に決めた交互順序等で各5回を初期案とする。送信・close、ローカルポート、試行IDを記録する。必要ならPCAPを併用して制御本文を照合する。

各試行でアプリ操作、サーバー受信、CSV行、正しいUID・不明・矛盾を別集計する。1試行1ソケット1送信の制御条件とし、パケット数を一般のフロー精度の分母にしない。反復試行を独立アプリ数に数えない。結果が明確なら、この原因調査は一区切りとして照合評価へ戻る。

3. HTTPS正常通信とHTTP接続失敗

GPT側で実行機能・APK・手順を用意し、手元で取得する。HTTPSは証明書検証が正常な宛先を使い、復号を必須にせずメタデータを評価する。ローカルCAや専用信頼設定を使う場合は別プロファイルとして記録する。

接続失敗では前後対照用サーバーを生かし、対象アプリの宛先だけを未使用ポートへ向ける。対照まで失敗する構成を「取得系が正常な失敗試行」としない。接続試行、UID識別、サーバー要求受信、HTTP応答を分離する。各条件3回は候補で、実行前に条件と成功基準を固定する。現行ランナーにはHTTPS/失敗専用コマンドは未配布。

4. ポリシー照合の比較

事前に許可・禁止・未指定の条件と評価単位を固定する。静的のみ/動的のみ/両方に同じ原本を使い、証拠の差を比較する。既存http-004の3条件×3方式は事後の説明用例であり、本評価と分ける。

正解はソース・独立サーバー・端末ログ等で作り、可能なら第三者に確認してもらう。取得器の出力だけを正解にしない。適合率/再現率だけでなく、評価可能率、判定不能、帰属不明、欠落・失敗を示す。分母0は未定義とする。

5. 最後に通信なしを追加確認

他のケース後に実施する。既存offline-auto-001を保持し、実施済み002/003の原本があれば先に照合する。取得前後対照、操作完了、観測窓、取得の継続申告をそろえた範囲で未観測を報告する。

6. 論文を仕上げる

文献調査は上記と並行して行う。ポリシー整合性・静的/動的解析・通信分析・SDK検出の査読本文を読み、既存研究との違いを確定する。表・図・証拠索引を更新し、著者情報、大学様式、指導教員確認を反映する。

分担

GPTで進める	手元または人が必要
単一APK化、シナリオ実装、規則・試験・集計	Emulatorで実行、VPN許可、PCAPdroid操作
原本hash/時刻/UID/サーバー照合	実際の操作・設定変更・失敗の記録
文献の読解、比較表、図表、TeX/PDF	入手制限がある査読本文の正規入手
研究範囲・正解表・説明の案	独立確認、指導教員との相談、著者の最終判断

現時点の論文で主張する範囲

静的・動的証拠を明示ポリシーへ照合し、不足情報を残して根拠へ追跡するシステムを実装した。少数の制御実測で、送受信とUID識別が別の状態であることを示した。未知アプリの検出精度、AI生成コードの危険性、SDK一般精度、手作業削減、新規取得技術の優越は未評価である。

本研究を「Unknownをなくす研究」に変更せず、Unknownや失敗を誤った結論に変換しない支援として完成させる。